Maemo Compliance Product Specification

Maemo Compliance — Product Specification

Document title: Maemo Compliance Product Specification
Product: Maemo Compliance
Publisher: Codist (Pty) Ltd
Version: 1.0
Date: July 2026
Classification: Client-facing — for evaluation and procurement
Website: https://maemo-compliance.co.za

Document control

Version	Date	Author	Summary of changes
1.0	July 2026	Codist Product Team	Initial client product specification

---

1. Executive summary

Maemo Compliance is a cloud-ready, multi-tenant compliance operations platform designed for South African organisations that need to manage documented management systems, corrective action, risk registers, and audit programmes in one secure workspace.

The platform helps teams **implement and maintain** requirements arising from standards such as **ISO 9001**, **ISO 14001**, **ISO 45001**, **ISO 27001**, and **POPIA**, alongside records-management practices aligned with **NARSA** and audit evidence practices aligned with **AGSA** expectations.

Maemo is **not** a full enterprise GRC (Governance, Risk & Compliance) suite. It is a **compliance operations layer**: document control, evidence, non-conformance management, risk registers, consultant-led audits, and POPIA-oriented access reporting — delivered as modular, tenant-licensed software that can be deployed on Codist-managed infrastructure or customer-controlled environments.

Key benefits

- **Single workspace** for policies, procedures, records, CAPA, risks, and audit evidence
- **South African context** — POPIA metadata, NARSA file-plan fields, BBBEE certificate tracking
- **Modular licensing** — enable only the modules each tenant needs
- **Consultant-ready** — consultants can manage multiple client tenants and run structured audits
- **Integration-ready** — Engine API (`/engine/v1/*`) for headless and third-party integration
- **Deployable** — Docker-based services; suitable for private cloud or on-premises deployment

---

2. Product overview

2.1 Purpose

Maemo Compliance reduces the operational burden of running a management system by providing:

1. Controlled document lifecycle management with approval workflow and versioning
2. Non-conformance and corrective action (CAPA) tracking with audit-finding linkage
3. A central risk register with inherent and residual scoring
4. Structured internal audit execution with evidence capture
5. POPIA-oriented personal-information access reporting on controlled documents
6. Records retention scheduling and archival/destruction support

2.2 Target users

Persona	Typical use
Quality / compliance manager	Document control, NCR oversight, audit preparation
Department owner	Maintain procedures, respond to findings, manage department risks
Internal auditor / consultant	Run audit templates, capture evidence, raise findings
Information security officer	ISMS documentation, information-security risks, POPIA trail
Tenant administrator	User invites, tenant settings, M365/SharePoint connection
Executive / reviewer	Dashboard summary, management review inputs

2.3 Supported standards (configuration & templates)

During signup and company setup, organisations select target standards. Maemo configures categories, onboarding seeds, and audit templates accordingly.

Standard / framework	Supported in product	Notes
ISO 9001:2015	Yes	Document template pack;

Standard / framework	Supported in product	Notes
		audit template seeded on onboarding
ISO 14001:2015	Yes	Environmental categories; audit template
ISO 45001:2018	Yes	Safety categories; audit template
ISO 27001:2022	Yes	Information security categories; audit template
POPIA	Yes	Document PII classification; data breach notification template; access trail report
ISO 31000	Partial	Risk categories seeded; no dedicated ISO 31000 template pack
NARSA / records	Yes	Retention schedule template; file-plan metadata on documents
AGSA audit evidence	Yes	Audit evidence register template
ISO 22301	Not yet	See companion document for adjacent support and roadmap

3. Architecture

3.1 Platform components

Maemo is delivered as a set of cooperating services:

Component	Role
Identity service	User registration, login, email verification, tenant provisioning, JWT issuance
Compliance engine	Documents, NCRs, risks, audits, departments, webhooks, API keys
Portal	Angular web application for tenant users
Workers	Scheduled jobs: records retention, email queue, compliance reminders
Public site	Marketing, contact, and access-request flows
Admin console	Codist internal administration (access requests, tenant oversight)

Production deployments use **PostgreSQL** as the system of record, **Docker** containers, and **nginx** reverse proxy with TLS termination. Authentication supports **Azure AD (MSAL)** and **local email/password** with JWT bearer tokens.

3.2 Multi-tenancy

Every compliance record is **tenant-scoped**. Users authenticate into a tenant context; API requests carry tenant identity via JWT claims and optional headers. This model supports:

- Isolated customer organisations on shared infrastructure
- Consultant users linked to multiple client tenants
- Per-tenant module licensing and configuration

3.3 Deployment models

Model	Description
Codist SaaS	Hosted on Codist-managed infrastructure (current production pattern)
Private cloud / VPS	Customer or partner-managed Docker deployment using published images
On-premises	Same container stack deployed inside customer network perimeter

File storage defaults to **local encrypted volume** in production; **Microsoft 365 / SharePoint** integration is available for organisations that prefer document storage in their tenant.

---

4. Functional modules

Modules are licensed per tenant via `ModulesEnabledJson`. Available module keys: **Documents**, **NCR**, **Risks**, **Audits**.

4.1 Documents module

Purpose: Control policies, procedures, forms, and records required by the management system.

Core capabilities

Capability	Description
Document register	Searchable list with category, department, workflow state, and review date
Approval workflow	Draft → Pending Approval → Approved → Active → Archived / Obsolete
Version control	Semantic versioning with upload/download per version
File integrity	SHA-256 hash stored per document for tamper detection
Review scheduling	Mandatory review dates on controlled documents
Approver controls	Role-based approval (`DocumentApprover` policy)
Template library	Pre-built ISO 9001, POPIA, NARSA, and AGSA starter templates
Evidence export	Client-side audit evidence HTML export from document detail

POPIA & records metadata

Field / feature	Purpose
PII classification	Classify documents containing personal information
Retention period (months)	POPIA-aligned retention on PII documents
Retain-until date	Records retention scheduling
NARSA file plan	Series, sub-series, and item classification
Destruction tracking	Audit trail when records are destroyed per retention policy
BBBEE certificate tracking	Expiry date and level (Levels 1–8) for transformation compliance

Workflow states

```
Draft → PendingApproval → Approved → Active → Archived
                                ↓
                          Obsolete (superseded)
```

Rejected documents return to Draft with a recorded reason.

4.2 NCR module (Non-Conformance & CAPA)

Purpose: Record, investigate, and close non-conformities, incidents, and corrective actions.

Core capabilities

Capability	Description
NCR register	Filter by status, severity, and department
Severity levels	Configurable severity classification
CAPA fields	Root cause, corrective action, owner, due dates, effectiveness confirmation
Status history	Full audit trail of status changes
Audit finding link	Create NCR directly from audit finding
Risk linkage	Link NCRs to risks in the risk register (bidirectional)
Escalation level	Supervisory → management → executive escalation tracking
Offline capture	Create NCR offline in browser; sync when connectivity returns

Typical use cases

- Quality non-conformities (ISO 9001)
- Safety incidents and near-misses (ISO 45001)
- Security events and control failures (ISO 27001)
- Post–business continuity exercise findings (ISO 22301 — via document/NCR process)

4.3 Risks module

Purpose: Maintain an organisation-wide risk register aligned to management system planning requirements.

Core capabilities

Capability	Description
Risk register	List, create, edit, and close risks
5×5 scoring	Inherent and residual likelihood × impact with calculated score
Risk categories	Operational, Financial, Compliance, Health & Safety, **Information Security**
Risk status lifecycle	Identified → Analysed → Mitigated → Accepted → Closed
Existing controls	Free-text description of current controls

Capability	Description
NCR linkage	Associate risks with open non-conformances
Review date	Scheduled risk review

Scope note

The risk register supports **ISO 31000-style** and management-system **risk-and-opportunity** processes. It is a **general register**, not a specialised occupational health & safety (HIRA) assessment tool with configurable hazard matrices — HIRA is on the product roadmap as a separate module.

4.4 Audits module

Purpose: Plan and execute internal audits; capture findings and evidence.

Core capabilities

Capability	Description
Audit templates	Reusable question sets grouped by category
Audit runs	Execute template against a scope; record answers
Evidence upload	Attach evidence files to individual audit answers
Findings	Record findings with severity; link to NCR
Consultant ownership	Templates owned by consultant users for multi-client practices
Onboarding seeds	ISO 9001, 14001, 45001, 27001 audit templates auto-created from selected standards
Integrated SHEQ template	Combined audit when multiple standards are selected

Audit programmes (API)

Yearly audit programmes with scheduled items and linked audit runs are supported at **API level**. Portal UI for programme management is planned.

Access path

Audit execution is currently accessed via the **Consultant workspace** routes. A dedicated top-level Audits navigation entry is planned for tenant-admin and internal-auditor personas.

4.5 POPIA compliance (cross-cutting)

POPIA is implemented as metadata and reporting across the Documents module, not as a separate licensed module.

Capability	Description
PII document classification	Tag documents containing personal information
Access trail report	Admin report showing who accessed PII-classified documents
CSV export	Export POPIA trail for regulator or internal audit
Data breach notification template	Starter POPIA form template in template library

4.6 Records retention (cross-cutting)

Capability	Description
Retention policy engine	Category-based default retention periods
Retention worker	Daily scan marks documents past retention
Destruction worker	Physical file deletion when enabled and approved
NARSA template	Records retention schedule starter document

5. User roles and access control

Role	Capabilities
Platform Admin	Codist internal — tenant provisioning, access requests
Tenant Admin	Full tenant configuration, user invites, NCR delete, settings
Tenant User	Standard compliance operations within licensed modules
Consultant	Multi-tenant client dashboard, audit templates and runs, branding

Module gating

Both API and portal enforce module licensing. Users without a licensed module cannot access that module's routes or endpoints.

Authentication

- Azure Active Directory (MSAL) — enterprise SSO
- Local email/password with email verification
- JWT bearer tokens with tenant and role claims

6. Consultant model

Maemo supports compliance consultants who serve multiple client organisations:

- **Consultant dashboard** — summary across linked client tenants
- **Client list** — navigate to client workspaces
- **Audit templates** — consultant-owned, reusable across clients
- **Branding** — consultant workspace branding (configuration API in progress)
- **Consultant–tenant links** — explicit relationship between consultant user and client tenant (identity service)

This model suits ISO implementation partners, SHEQ consultants, and internal audit service providers.

---

7. Integrations and API

7.1 Engine API

Headless REST API at `/engine/v1/` for integrations:

Resource	Operations
Documents	CRUD, upload, download, versions
NCRs	CRUD, status, history, risk links
Risks	CRUD, NCR linkage
Audits	Templates, runs, answers, evidence, findings
Webhooks	Subscribe to compliance events
API keys	Machine-to-machine authentication

Authentication: JWT or API key with tenant scope.

7.2 Microsoft 365

- Azure AD sign-in
- SharePoint document storage (optional; environment-dependent)
- Tenant M365 connection wizard

7.3 Email

Transactional email via **Resend** for registration, verification, invitations, and access-request notifications.

---

8. Onboarding and starter content

8.1 Signup and company setup

Self-service signup (Starter plan) or Growth plan with access-request approval:

1. User and company profile
2. Industry and company size
3. Target standards selection (ISO 9001, 14001, 45001, 27001, POPIA)
4. Plan selection

8.2 Automated seeding

On completion of company setup, Maemo seeds:

- Document categories matched to selected standards
- Risk category preferences
- Audit templates for each selected ISO standard
- Dashboard widgets appropriate to selected standards
- Default departments (configurable)

8.3 Template library

Pack	Contents
ISO 9001	Quality manual overview, control of documents, control of records, internal audit procedure, management review, NCR/CAPA, risk & opportunity, training & competence
POPIA	Data breach notification form
NARSA	Records retention schedule
AGSA	Audit evidence register

Templates are Markdown-based with merge fields (e.g. `{{CompanyName}}`, `{{ISOStandard}}`) populated on document creation.

---

9. Notifications and background processing

Job	Behaviour
Records retention scan	Marks documents past retention date
Document destruction	Deletes files when retention policy and config allow
Compliance jobs worker	Logs upcoming document reviews, overdue NCRs, high risks, retention warnings
Email queue worker	Sends queued transactional and reminder emails (split workers service)

Compliance event email notifications (review due, overdue NCR) are **partially implemented** — worker detection exists; full outbound email for all event types is on the roadmap.

---

10. Technical specification summary

Attribute	Specification
Backend	.NET 8, Minimal APIs, MediatR, FluentValidation
Database	PostgreSQL 16
Frontend	Angular (portal), PrimeNG UI components
Authentication	JWT (RS256), Azure AD MSAL

Attribute	Specification
File storage	Local volume or SharePoint
Container runtime	Docker / Docker Compose
CI/CD	GitHub Actions → GHCR → SSH deploy
Testing	xUnit unit tests, Testcontainers integration tests, Playwright E2E

11. Security and data protection

Control area	Implementation
Tenant isolation	Tenant-scoped data model; tenant context on every request
Transport security	TLS via nginx in production
Authentication	Industry-standard JWT; optional Azure AD federation
File integrity	SHA-256 hashes on stored documents
POPIA	PII classification, access trail reporting, retention metadata
Audit logging	Technical audit log and business audit log entities
Service-to-service	Internal API key for identity service calls

Organisations requiring ISO 27001 certification should implement complementary technical controls (network segmentation, SIEM, backup, DR) in their hosting environment. Maemo provides the **management system tooling**; infrastructure security remains a shared responsibility between Codist and the customer depending on deployment model.

12. Licensing and plans

Plan	Description
Starter	Self-service activation, 14-day trial, up to 5 users, 1 GB storage (configurable)
Growth	Access-request approval workflow; tenant activated after Codist review

Module licensing (Documents, NCR, Risks, Audits) is configured per tenant. Billing integration (PayFast) exists but is feature-flagged; enterprise contracts are typically invoiced directly.

13. Product roadmap (indicative)

The following capabilities are in development or planned. Dates are indicative and subject to change.

Capability	Status
Service architecture cutover (identity, engine, portal, workers)	In progress
HIRA module (configurable matrices, hazard library, OHS assessments)	In development (split repos)
Consultant multi-tenant JWT claims	In development
Audit programmes portal UI	Planned
Full compliance event email notifications	Planned
ISO 22301 template pack and BCM-specific registers	Planned
Enterprise reporting and combined assurance dashboards	Planned

14. Professional services

Codist offers implementation services alongside the software:

Service	Description
Tenant provisioning and configuration	Standards selection, category setup, user onboarding
Template customisation	Branded procedures and policies from starter templates
Data migration	Import from spreadsheets or legacy systems
Consultant onboarding	Multi-tenant setup for audit practices
Training	Administrator and end-user training
Managed hosting	Codist-operated SaaS with SLA

Contact: **technical@codist.co.za** | https://maemo-compliance.co.za/contact

15. Limitations and exclusions

Prospective clients should note the following current limitations:

1. Maemo is a **compliance operations platform**, not a certified GRC product with pre-mapped control libraries for every ISO Annex A control.
2. **ISO 22301** business continuity management is **not yet a dedicated module** — adjacent features (documents, risks, NCR, audits) support BCM processes; see companion ISO document.
3. **HIRA** (occupational risk assessment with hazard matrices) is on the roadmap; the current Risks module is a general register.
4. Some admin UI endpoints (records retention list, dashboard POPIA widgets) are incomplete in the current release.
5. Software supports certification efforts; **certification itself** requires organisational processes, competent auditors, and accredited certification bodies.

16. Glossary

Term	Definition
CAPA	Corrective and Preventive Action
ISMS	Information Security Management System
BCMS	Business Continuity Management System
NCR	Non-Conformance Report
POPIA	Protection of Personal Information Act (South Africa)
NARSA	National Archives and Records Service of South Africa
SHEQ	Safety, Health, Environment, and Quality
Tenant	An isolated organisation workspace in Maemo

---

17. Disclaimer

This document describes Maemo Compliance as implemented and planned at the time of publication. Features marked as planned or in progress are not contractual commitments unless captured in a signed statement of work or licence agreement. Codist (Pty) Ltd reserves the right to modify product capabilities as part of normal development.

For a standards-specific mapping, refer to the companion document: **Maemo Compliance — ISO 27001 & ISO 22301 Support Guide**.

Codist (Pty) Ltd
Product: Maemo Compliance
Web: https://maemo-compliance.co.za
Email: technical@codist.co.za

End of document